

Bug Bounty Report

Unauthenticated Access to /api/chat — flollama.in

Field	Detail
Target	flollama.in
Endpoint	POST https://flollama.in/api/chat
Severity	HIGH
Date	May 29, 2026
Reported by	Hassan
Backend	Identified as Gemini Flash during testing
Auth Required	None

1. Summary

The **/api/chat** endpoint on **flollama.in** is publicly accessible without any form of authentication. The endpoint proxies requests directly to a backend LLM API (identified as Gemini Flash during testing) using a server-side API key. Any unauthenticated attacker can send unlimited requests to this endpoint at the owner's expense — no account, session token, or API key required.

2. Steps to Reproduce

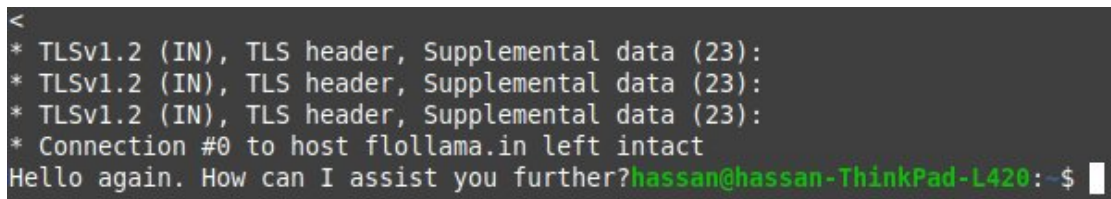
No account or browser required. Run from any machine:

```
curl -X POST https://flollama.in/api/chat \ -H "Content-Type: application/json" \ -d '{"messages":[{"role":"user","content":"hello"}]}' \ -v
```

Response:

```
HTTP/2 200 content-type: text/plain; charset=utf-8 server: Vercel Hello again. How can I assist you further?
```

Proof — curl Response (Terminal Screenshot):



```
<
* TLSv1.2 (IN), TLS header, Supplemental data (23):
* TLSv1.2 (IN), TLS header, Supplemental data (23):
* TLSv1.2 (IN), TLS header, Supplemental data (23):
* Connection #0 to host flollama.in left intact
Hello again. How can I assist you further?hassan@hassan-ThinkPad-L420:~$
```

Figure 1: Unauthenticated curl request returning a valid LLM response from flollama.in/api/chat

3. Root Cause

The Vercel-hosted Next.js API route at **/api/chat** forwards user messages to the backend LLM with no session check, no authorization header validation, and no API key requirement on the client side. The backend API key is stored server-side but is effectively shared with the entire internet.

4. Impact

Financial: Attacker can exhaust the owner's API quota at will with no rate limit or throttle in place.

Abuse: Endpoint can be scripted to send thousands of requests per minute.

Untraceability: No authentication means abuse cannot be attributed or blocked per user.

Zero barrier: A single curl command is the entire exploit — no tooling or skill required.

5. Proof of Concept

Tested from a fresh Linux terminal (curl/7.81.0, Hassan's ThinkPad L420) with no cookies, no session, and no authentication headers. Received a valid LLM response with HTTP/2 200. The x-vercel-id header confirms the request hit origin servers (sin1::iad1), not a cache. See Figure 1 above for terminal screenshot.

6. Recommendations

1. Add server-side authentication — verify a valid session or JWT before forwarding to the LLM backend.
2. Implement rate limiting per IP using Vercel Edge Middleware or Upstash.
3. Require user login before accessing /api/chat.
4. Monitor and alert on abnormal API usage spikes in the provider dashboard.
5. **Optional:** If you are open to migrating the backend, I am available to help rebuild this API in Flask with proper authentication middleware, rate limiting, and secure API key handling — feel free to reach out.

Submitted in good faith as part of responsible disclosure. — Hassan